COMPLIANCE ASSESSMENT



AYUSH KUMAR JHA

05.02.2025

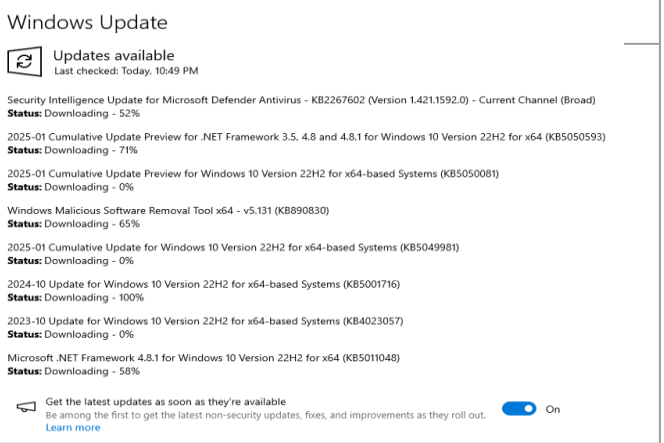
Section 1:
Developing a Hardening Strategy

Windows 10 Hardening

1. System Updates

Tips to hardening are:

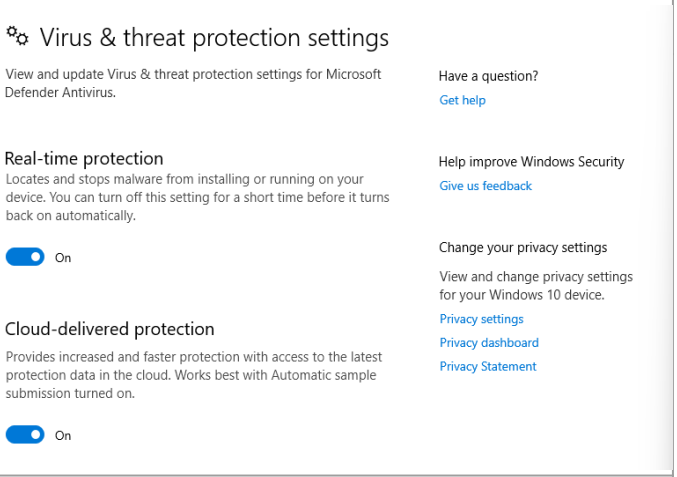
1. Enable AUTOMATIC UPDATES and ensure they include drivers and quality updates.
2. Regularly check for pending updates and verify installation success.



2. Antivirus Status

Tips to hardening are:

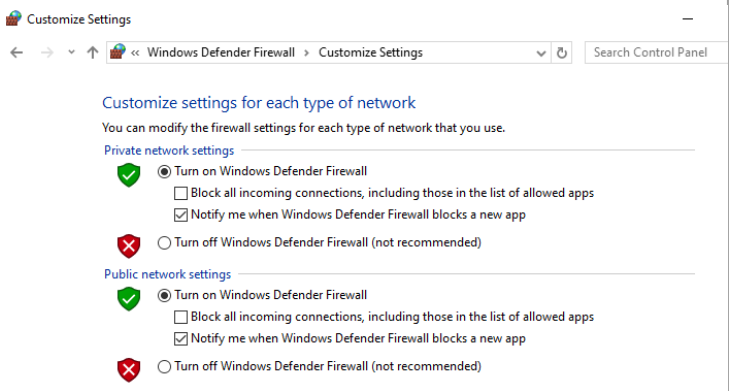
1. Turn on REAL-TIME PROTECTION and CLOUD-DELIVERED PROTECTION.
2. Monitor protection updates to keep virus definitions current.



3. Firewall Settings

Tips to hardening are:

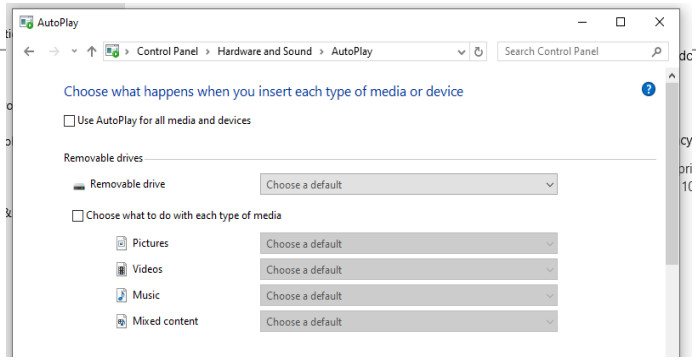
1. Ensure the firewall is enabled for both PRIVATE & PUBLIC profiles.
2. Monitor firewall logs for suspicious activity.



Windows 10 Hardening

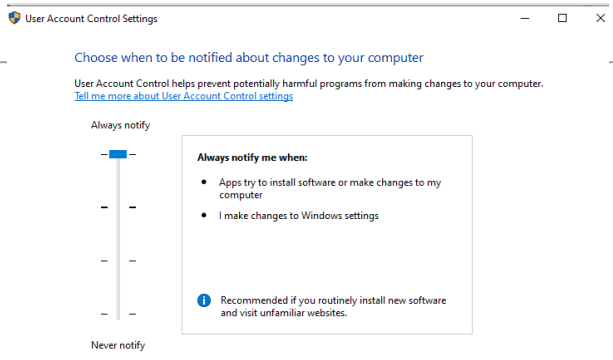
4. AutoRun/AutoPlay

1. Disable AutoPlay for all devices by unchecking USE AUTOPLAY for all media and devices.
2. Manually scan USB devices or CDs before accessing them.



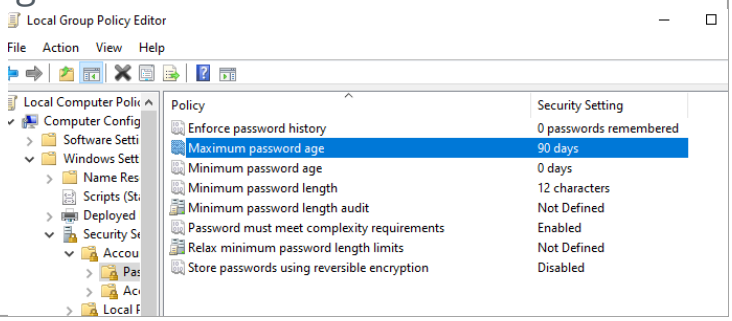
5. User Account Control Settings

1. Set user account control to the highest level.
2. Avoid disabling universal account control setting even for administrative accounts



6. Password Policies

1. Setting minimum password length of 12 characters.
2. Enable password complexity.
3. Set passwords to expiry 90 days.



MacOS Hardening

1. Enabling FileVault for Full-Disk Encryption
File Vault encrypts the entire drive, ensuring that if a MacBook is lost or stolen, unauthorized users cannot access corporate data. Encryption is crucial for compliance with NIST, ISO
2. Enforce Strong Password Policies and Enable Touch ID
A strong password policy mitigates brute-force attacks, while Touch ID adds an extra layer of biometric security for authentication. This ensures only authorized employees can access the device.
3. Enable Firewall & Block Unauthorized Incoming Connections
The macOS firewall helps prevent unauthorized access to network services, blocking malicious inbound traffic while allowing necessary business applications.

MacOS Hardening

4. Configure System & Application Updates for Automatic Installation
Keeping macOS and installed applications up to date is critical for patching security vulnerabilities that could be exploited attackers.
5. Restrict USB & External Device Access
USB ports and external storage devices can be used to exfiltrate corporate data or introduce malware into the system. Restricting their use enhances data security.
6. Enforce Endpoint Protection with Xprotect & Third-Party Security Tools
macOS includes XProtect, Apple's built-in malware detection system. But additional Endpoint Detection and Response solutions like CrowdStrike Falcon, Microsoft Defender for Mac, or SentinelOne real time monitoring and advance threat protection

Section 2:
Create Security Policies

Email Policy

1. Prohibition of Personal and Unauthorized Use:
Employees must use corporate emails accounts strictly for business purposes. Personal email accounts must not be used for company related communications. Unauthorized forwarding of iternal emails to external accounts is probited.

2. Phishing and Social Engineering Awareness:
Employees must not open attachments or clicks on links from unknown or unverified senders. Any suspicious emails must be reported immediately to the IT Security tem via the designated reporting mechanism. Employees should undergo regular phishing awareness training to recognize and handle phishing attempts.

3. Email Encryption and Secure Transmission:
Sensitive or confidential information must be encrypted before sending. Employees should use end-to-end encryption solutions like PGP,S/MIME,or the company's approved secure email gateway. Avoid sending sensitive data over email whenever possible-use secure file-sharing services instead.

4. Strong Authentication and Access Control:
Multi-Factor Authentication must be enabled for accessing corporate email accounts. Employee must logout of emails accounts when using shared or public computers. Passwords must comply with the corporate password policy.

5.Email Retention and Auto-Deletion Policy:
Employees must not store sensitive data in email indefinitely. Instead critical data must be archived securely. Emails older than a certain period of time as set by the company poilicies shall be automatically deleted unless flagged for retention. Employees must follow the company's email classification guidelines to determine retention period for different types of data.

BYOD Policy

1. Mandatory Device Enrollment and Mobile Device Management:- All employee owned devices accessing corporate resources must be enrolled in the company's mobile device management platform. It enforced security policies such as device encryption,remote wipe, application control, and compliance monitoring. Unauthorized or non-compliant devices will be denied access to corporate systems.
2. Multi-Factor Authentication:- Access to corporate email, VPN, and internal applications requires Multi-Factor Authentication. Employees must enable biometric authentication or a strong password(minimum of 12 characters) and devices must auto-lock after 5 mintues of inactivity.
3. Location Tracking and Lost Device Recovery:- Employees must enable FIND MY DEVICE for lost device recovery. IT Security may track a device only if it contains corporate data and is reported lost or stolen.
4. Restriction on USB and External Storage Devices:- Unauthorized USB drives and external hard drives are prohibited from storing company data. Dara transfers should be conducted only through encrypted cloud services or corporate-approved USB devices
5. Phishing and Social Engineering Awareness:- Employees must complete mandatory phishing awareness training. Suspicious emails, texts, or calls requesting sensitive data must be reported immediately to IT Security
6. Device Offboarding and Access Revocation:- Corporate access will be revoked immediately when an employee leaves the company. The company reserves the right to remotely remove corporate data before an employee departments

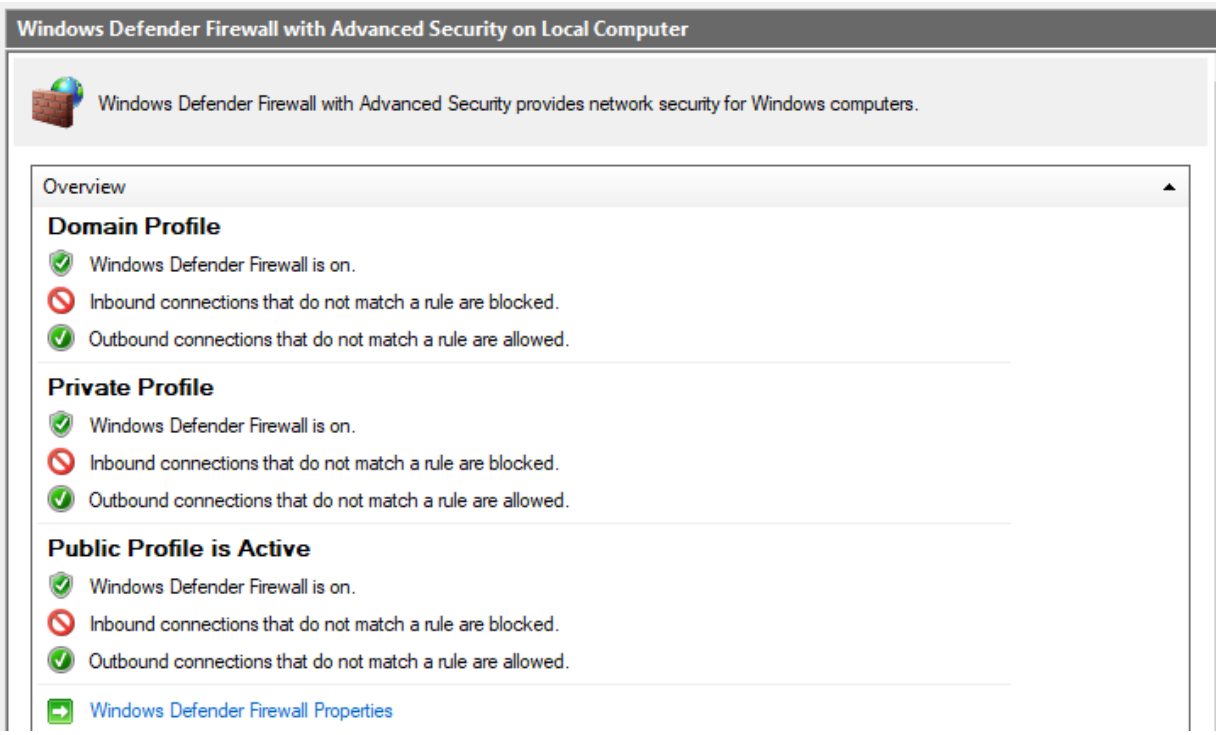
Section 3:
Self Assessment

Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
Built-In Administrator account is disabled	MET
Windows Firewall is enabled	MET
Automatic updates are enabled	MET
User Account Control (UAC) is enabled	NOT MET
Strong password policies are enforced	NOT MET
Guest account is disabled	NOT MET
System logging and auditing are enabled	MET
Windows Defender Antivirus is enabled and up to date	NOT MET
Remote Desktop Services are configured securely	NOT MET
Internet Explorer Enhanced Security Configuration (IE ESC) is enabled	NA
USB ports are disabled or restricted to authorized devices only	NOT MET
Network access controls are implemented, including VLAN segmentation and port security	NA
Remote Registry service is disabled	MET
Windows Updates are configured to download and install updates automatically	NOT MET

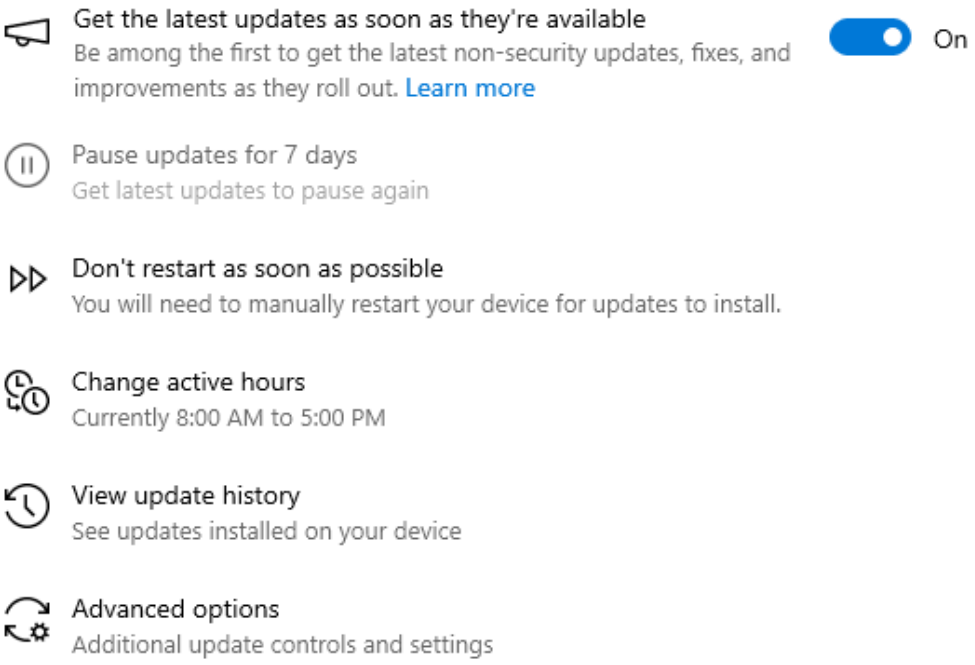
Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
Windows Firewall is enabled	MET



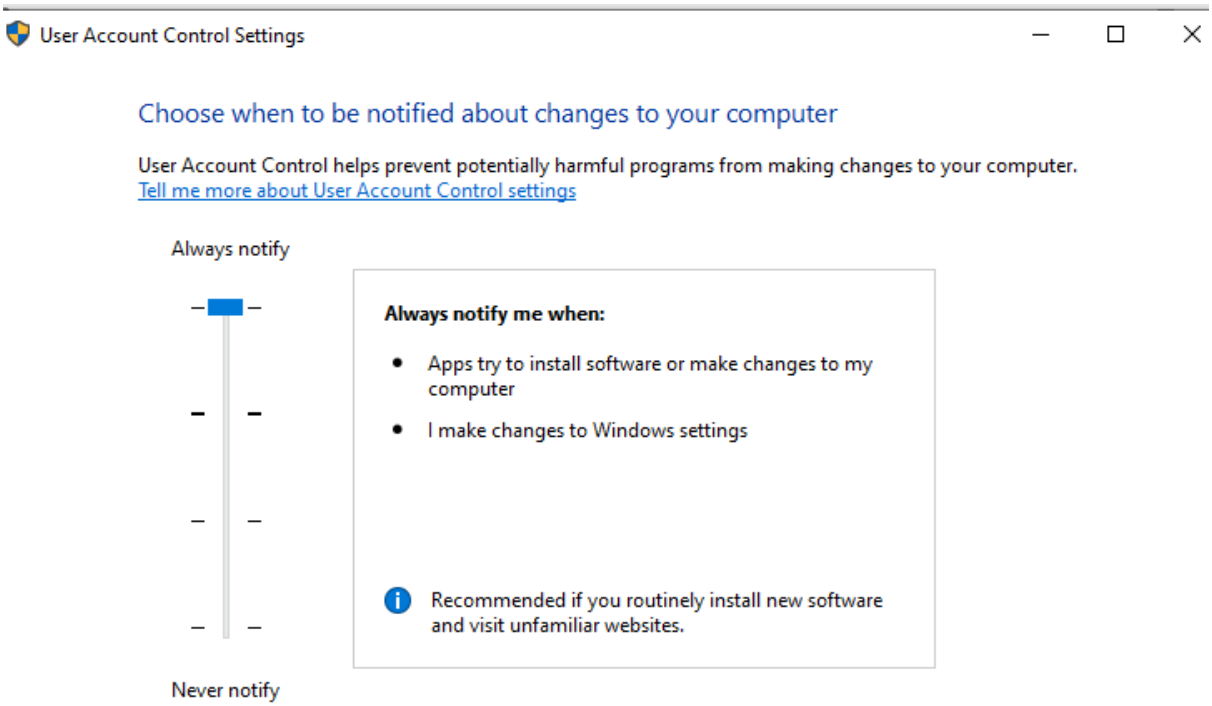
Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
Automatic updates are enabled	MET



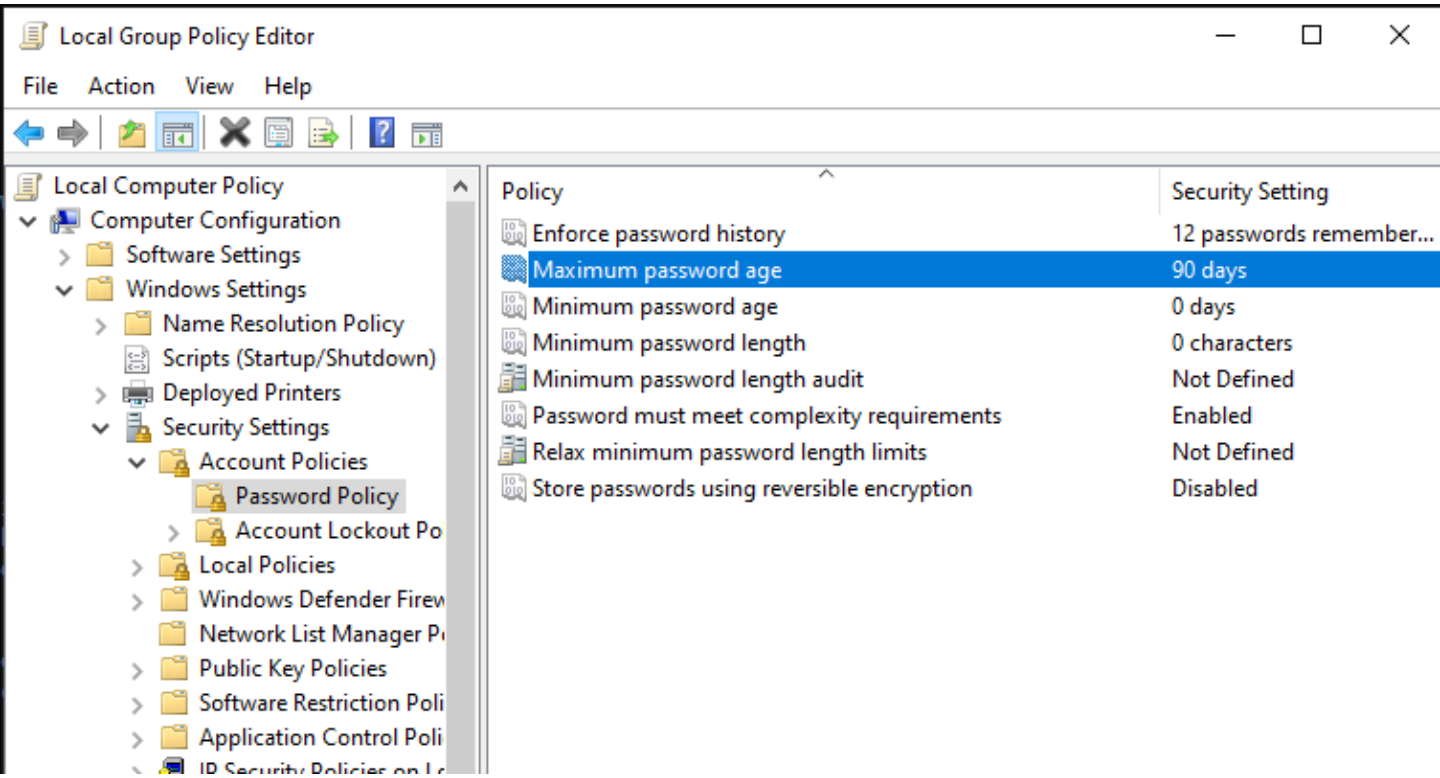
Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
User Account Control (UAC) is enabled	NOT MET



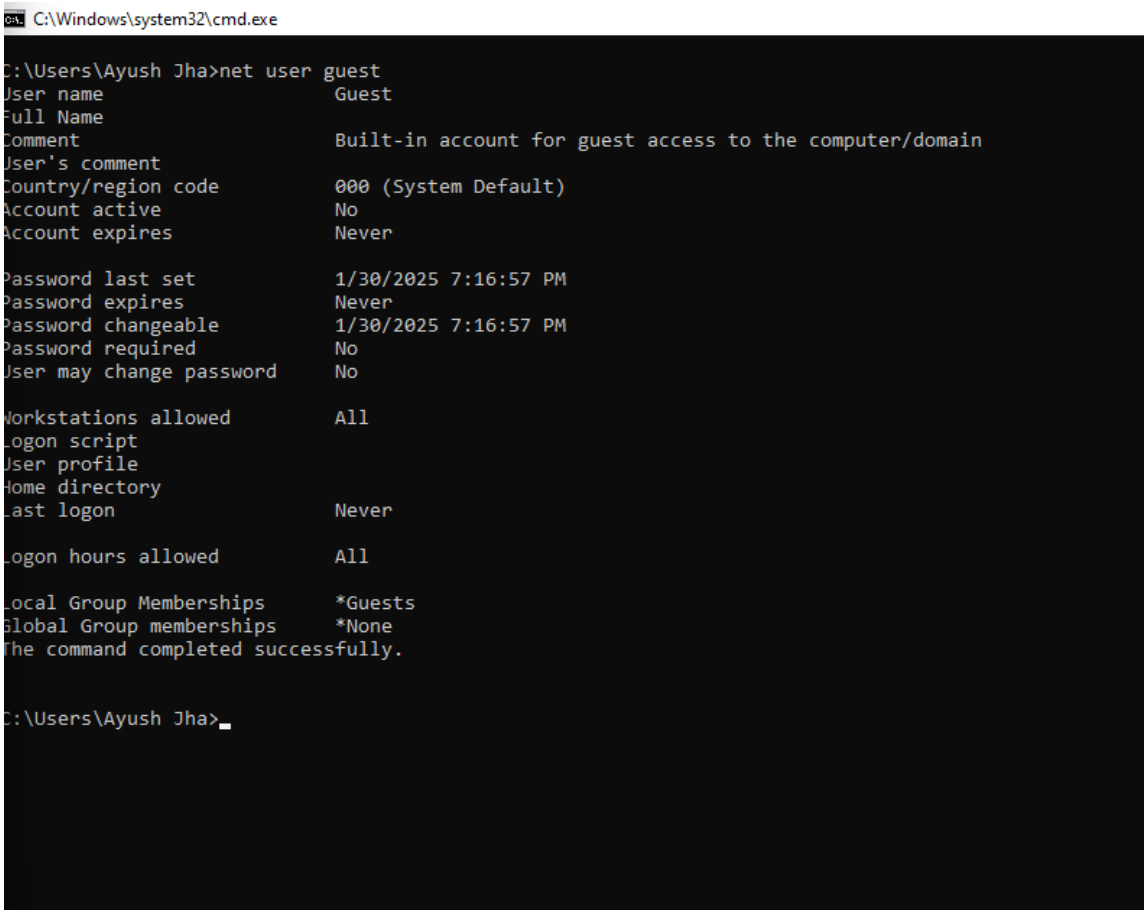
Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
Strong password policies are enforced	NOT MET



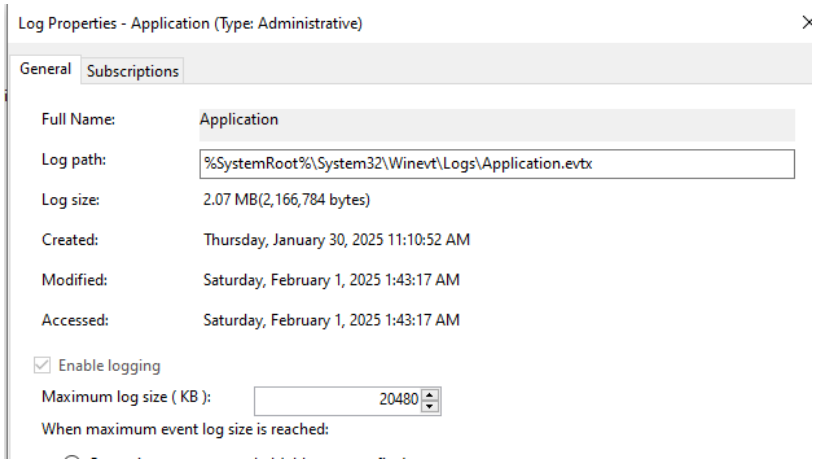
Windows Desktop Compliance

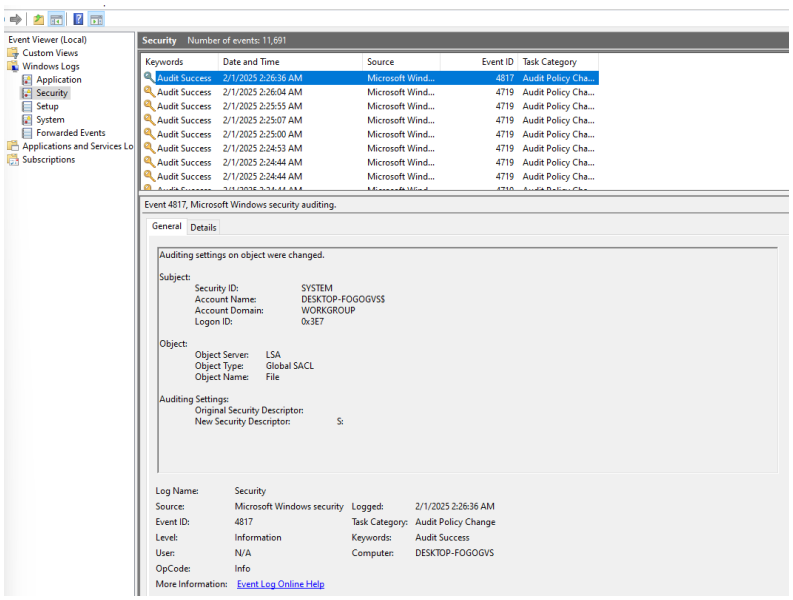
Windows 10 Regulatory Requirement	Met/Not Met
Guest account is disabled	NOT MET



Windows Desktop Compliance

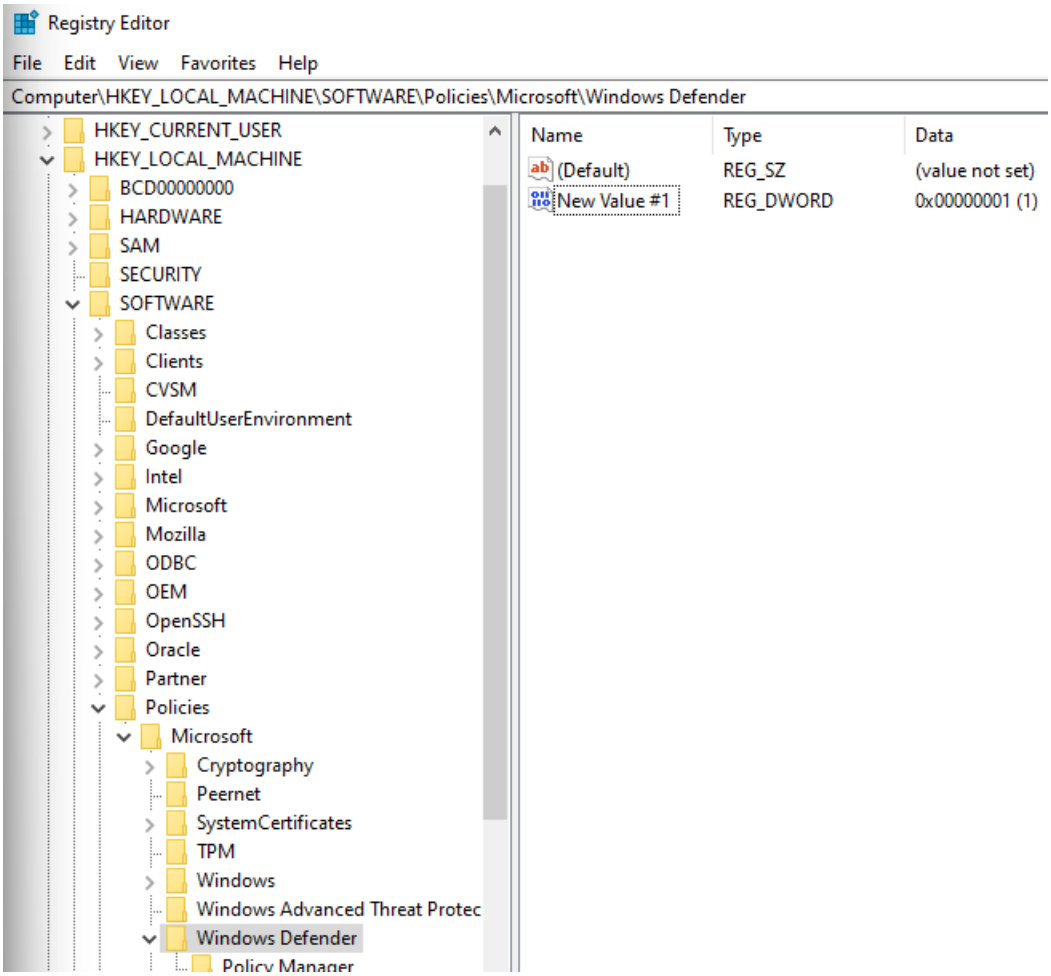
Windows 10 Regulatory Requirement	Met/Not Met
System logging and auditing are enabled	MET





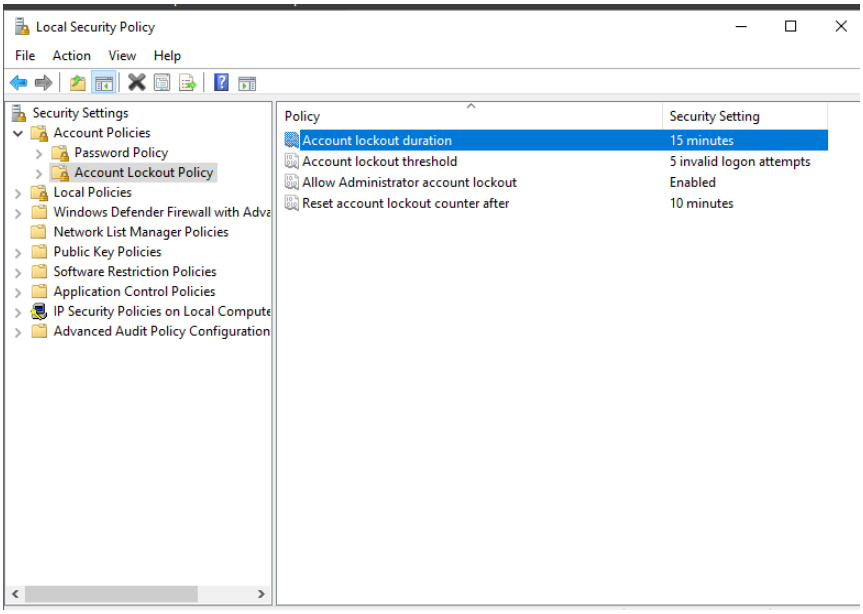
Windows Desktop Compliance

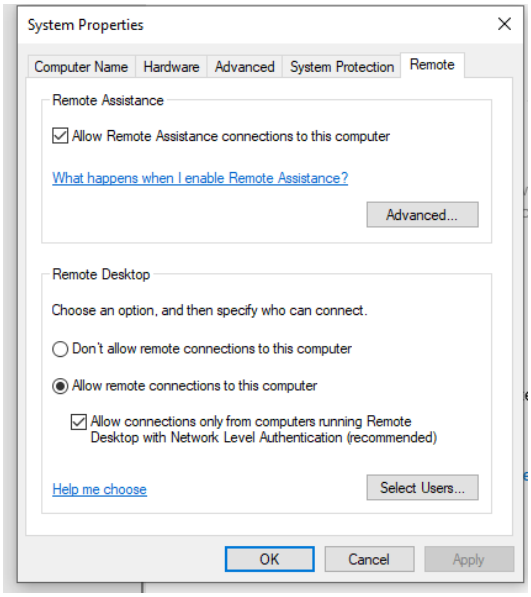
Windows 10 Regulatory Requirement	Met/Not Met
Windows Defender Antivirus is enabled and up to date	NOT MET

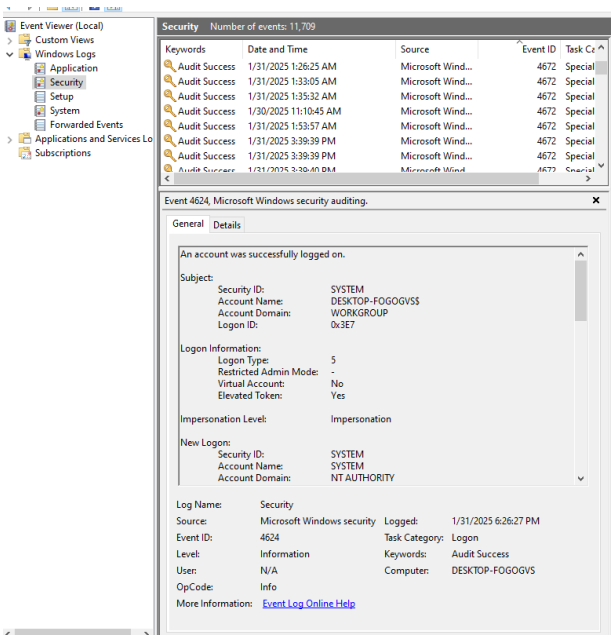


Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
Remote Desktop Services are configured securely	MET





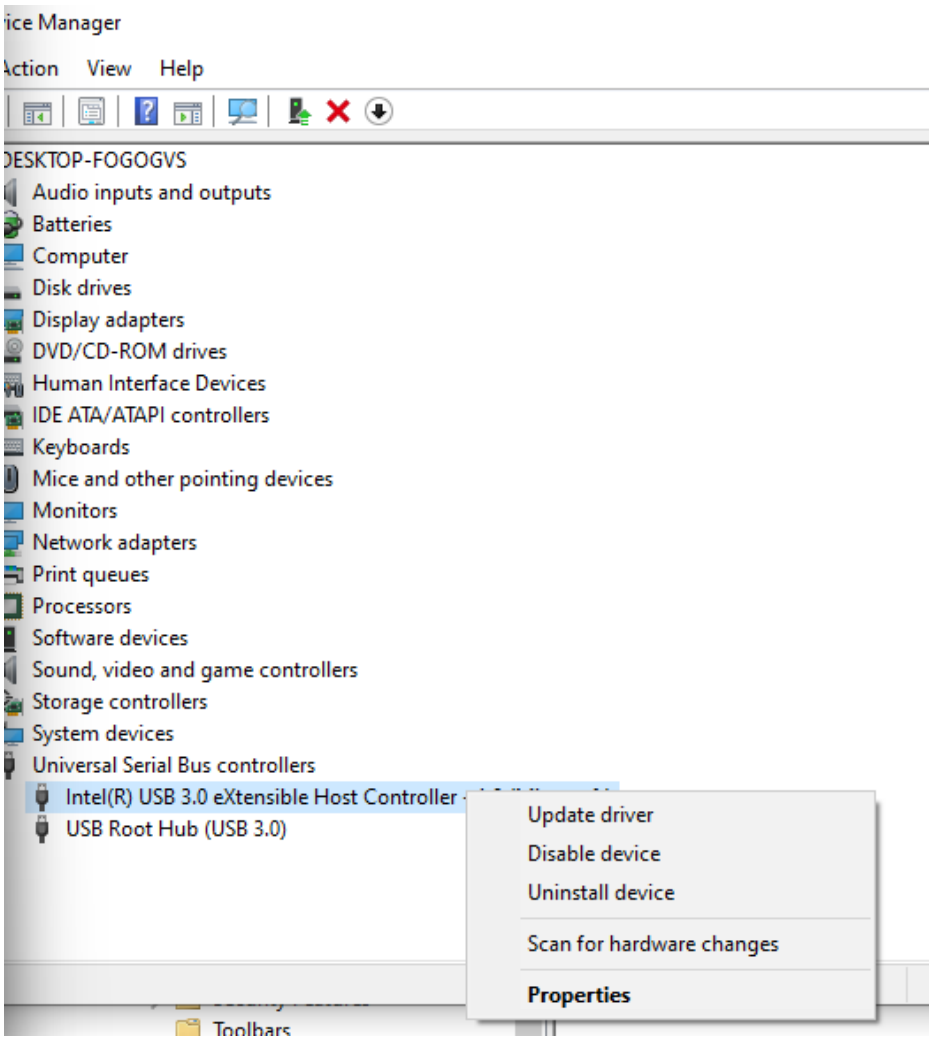


Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
Internet Explorer Enhanced Security Configuration (IE ESC) is enabled	NA

Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
USB ports are disabled or restricted to authorized devices only	NOT MET

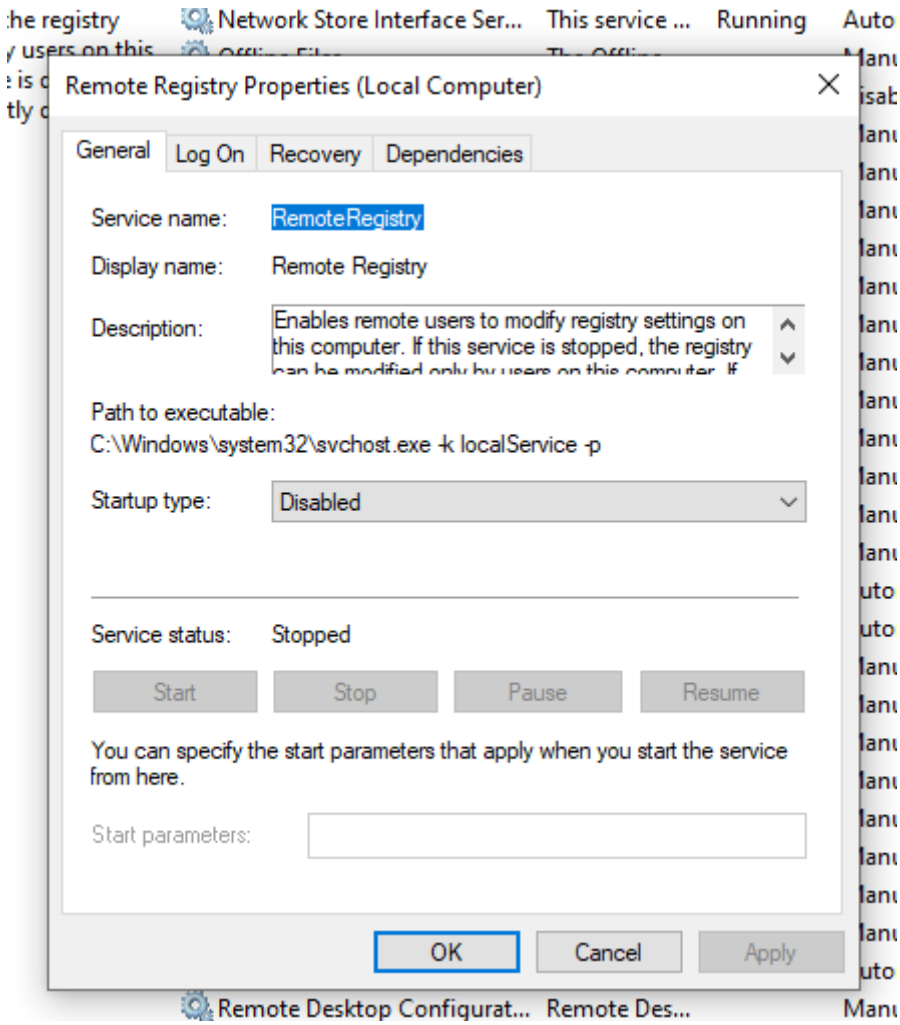


Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
Network access controls are implemented, including VLAN segmentation and port security	NA

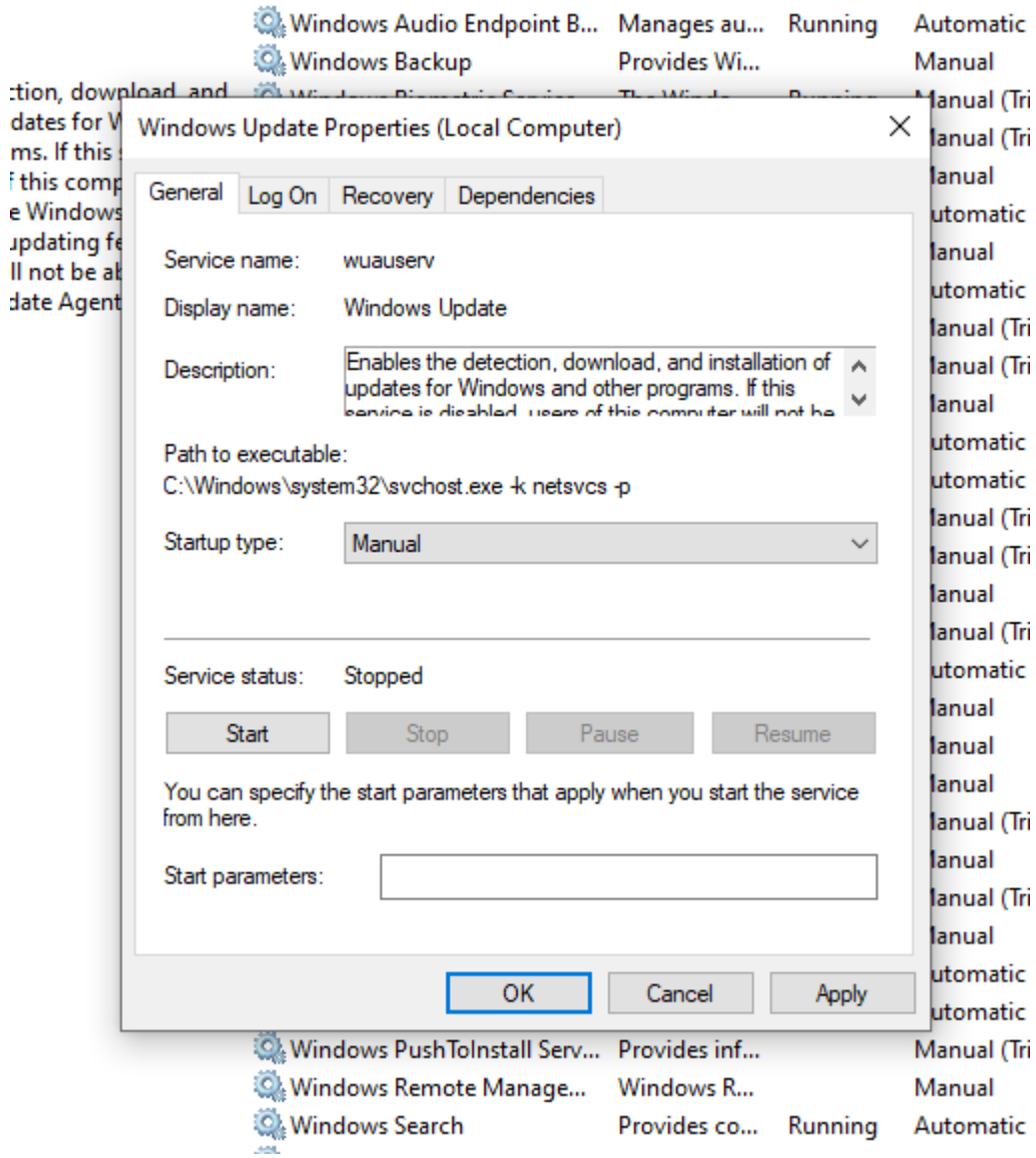
Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
Remote Registry service is disabled	MET



Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
Windows Updates are configured to download and install updates automatically	NOT MET



Windows Desktop Compliance

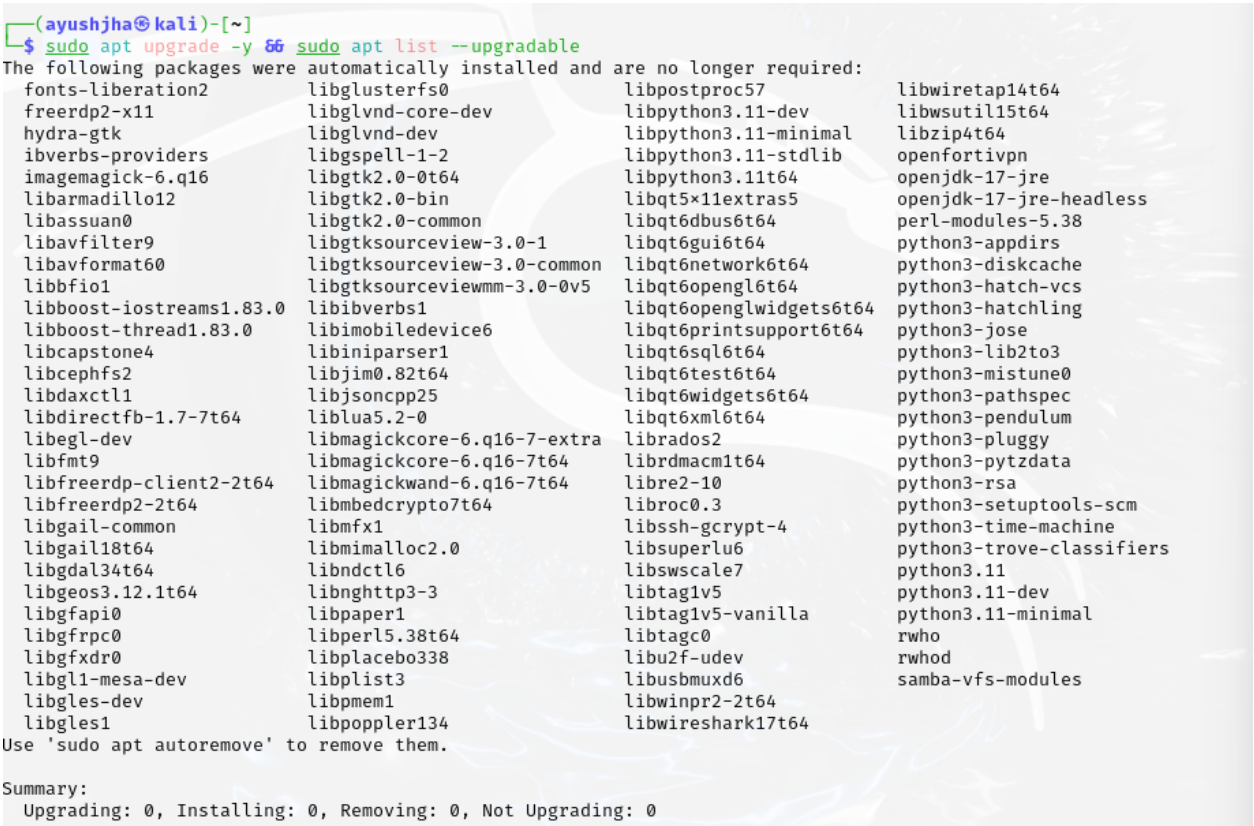
Windows Updates are configured to download and install updates automatically : Click on start button and open SERVICES. Search for Windows Update and click on it and automate the process
Windows Defender Antivirus is enabled and up to date : Open Registry Editor and click on LOCAL_MACHINE to get a pop-up for different options. Under SOFTWARE find POLICIES and click on it to find MICROSOFT DEFENDER. Click on it and set a new value and set it to1 to on it
Strong password policies are enforced: Run gpedit.msc and open Local Policies. Enforce complex passwords,expiratio,and history requirements
User Account Control is enabled : Open User Account Control Setting from User Accounts in CONTROL PANEL. Set the UAC to “ALWAYS NOTIFY” for maximum security

Linux Compliance

Linux CMMC Requirements	Met/Not Met
Current on security updates	MET
Ensure separate partition exists for /var	MET
Disable Automounting of drives	NOT MET
Ensure AIDE is installed	MET
Ensure daytime services are not enabled	MET
Ensure echo services are not enabled	NOT MET
Ensure tftp server is not enabled	MET
Ensure CUPS is not enabled	MET
Ensure DHCP Server is not enabled	MET
Ensure FTP Server is not enabled	MET
Ensure Samba is not enabled	MET
Ensure TCP Wrappers is installed	MET
Ensure DCCP is disabled	NOT MET
Ensure iptables is installed	MET
Ensure audit log storage size is configured	NOT MET
Ensure audit logs are not automatically deleted	NOT MET

Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Current on security updates	MET

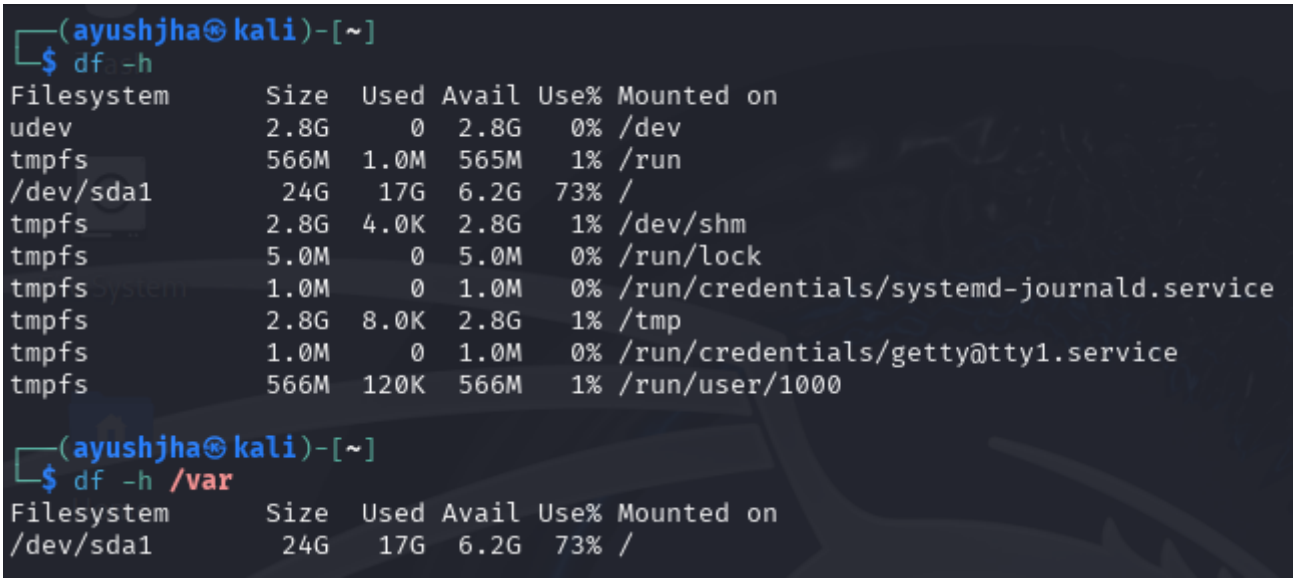


```
┌──(ayushjha㉿kali)-[~]
└─$ sudo apt upgrade -y && sudo apt list --upgradable
The following packages were automatically installed and are no longer required:
  fonts-liberation2          libglusterfs0              libpostproc57              libwiretap14t64
  freerdp2-x11               libglvnd-core-dev          libpython3.11-dev          libwsutil15t64
  hydra-gtk                  libglvnd-dev               libpython3.11-minimal      libzip4t64
  ibverbs-providers          libgspell-1-2              libpython3.11-stdlib       openfortivpn
  imagemagick-6.q16          libgtk2.0-0t64             libpython3.11t64           openjdk-17-jre
  libarmadillo12             libgtk2.0-bin              libqt5x11extras5           openjdk-17-jre-headless
  libassuan0                 libgtk2.0-common           libqt6dbus6t64             perl-modules-5.38
  libavfilter9               libgtksourceview-3.0-1     libqt6gui6t64              python3-appdirs
  libavformat60              libgtksourceview-3.0-common libqt6network6t64         python3-diskcache
  libbfio1                   libgtksourceviewmm-3.0-0v5 libqt6opengl6t64           python3-hatch-vcs
  libboost-iostreams1.83.0   libibverbs1                libqt6openglwidgets6t64    python3-hatchling
  libboost-thread1.83.0      libimobiledevice6          libqt6printsupport6t64     python3-jose
  libcapstone4               libiniparser1              libqt6sql6t64              python3-lib2to3
  libcephfs2                 libjim0.82t64              libqt6test6t64             python3-mistune0
  libdaxctl1                 libjsoncpp25               libqt6widgets6t64          python3-pathspec
  libdirectfb-1.7-7t64       liblua5.2-0                libqt6xml6t64              python3-pendulum
  libegl-dev                 libmagickcore-6.q16-7-extra librados2                 python3-pluggy
  libfmt9                    libmagickcore-6.q16-7t64   librdmacm1t64              python3-pytzdata
  libfreerdp-client2-2t64    libmagickwand-6.q16-7t64   libre2-10                  python3-rsa
  libfreerdp2-2t64           libmbedcrypto7t64          libroc0.3                  python3-setuptools-scm
  libgail-common             libmfx1                    libssh-gcrypt-4            python3-time-machine
  libgail18t64               libmimalloc2.0             libsuperlu6                python3-trove-classifiers
  libgdal34t64               libndctl6                  libswscale7                python3.11
  libgeos3.12.1t64           libnghttp3-3               libtag1v5                  python3.11-dev
  libgfapi0                  libpaper1                  libtag1v5-vanilla          python3.11-minimal
  libgfrpc0                  libperl5.38t64             libtagc0                   rwho
  libgfxdr0                  libplacebo338              libu2f-udev                rwhod
  libgl1-mesa-dev            libplist3                  libusbmuxd6                samba-vfs-modules
  libgles-dev                libpmem1                   libwinpr2-2t64
  libgles1                   libpoppler134              libwireshark17t64
Use 'sudo apt autoremove' to remove them.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0
```

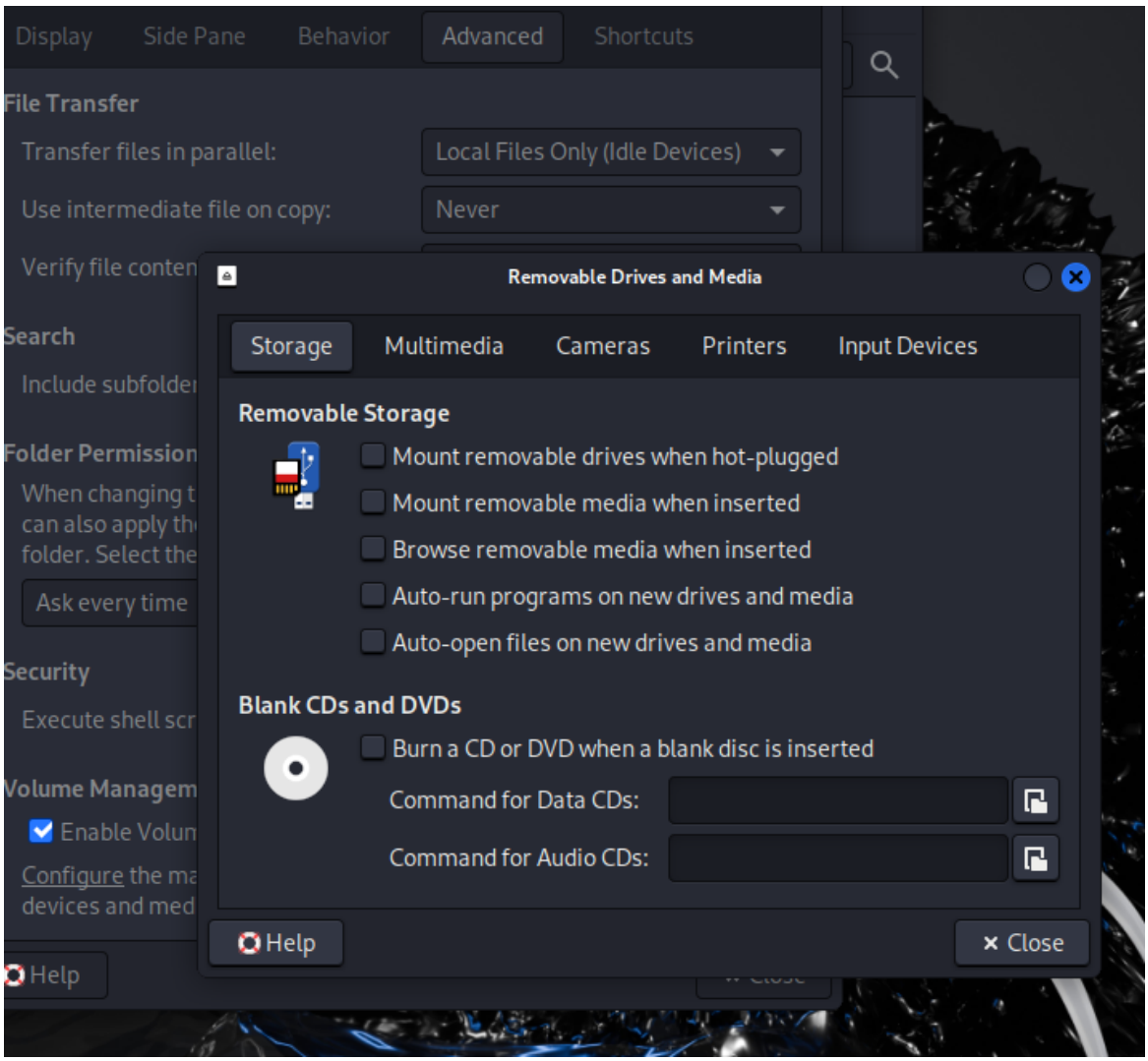
Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure separate partition exists for /var	MET



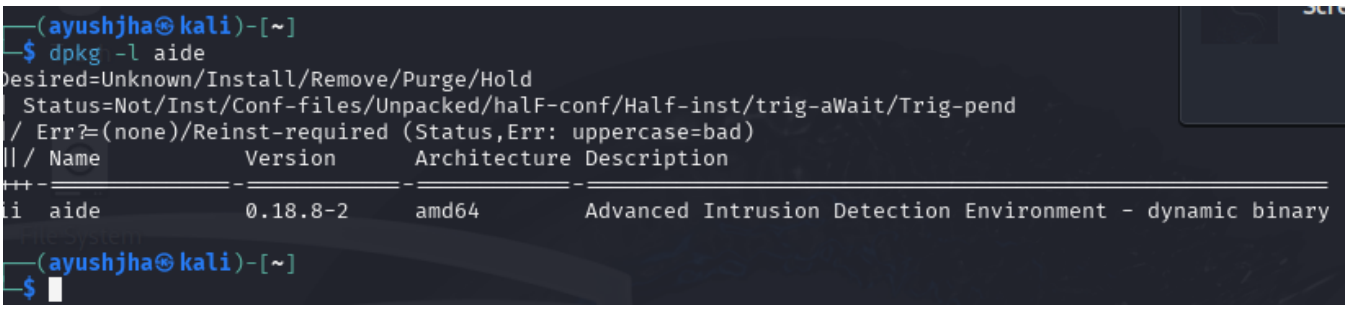
Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Disable Automounting of drives	NOT MET



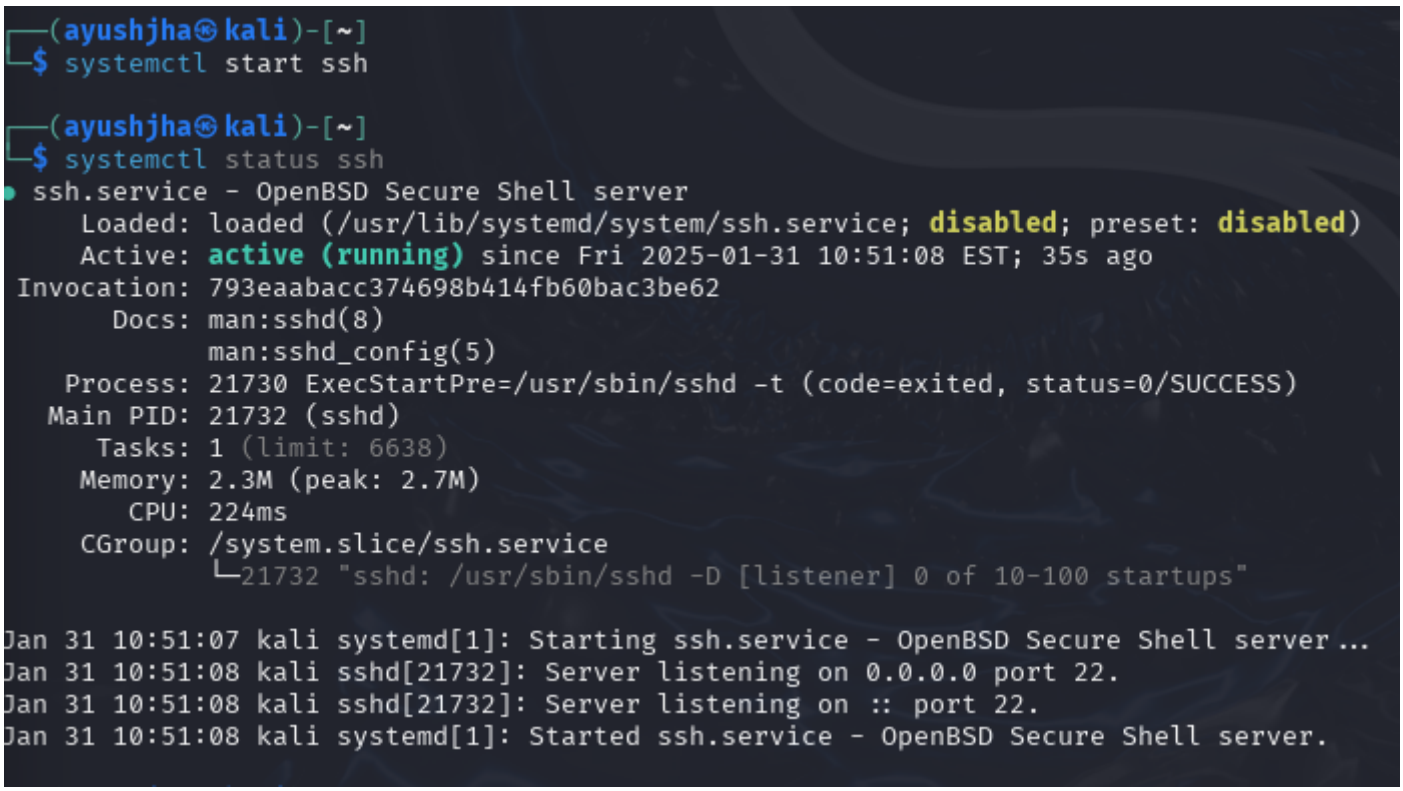
Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure AIDE is installed	MET



Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure daytime services are not enabled	MET

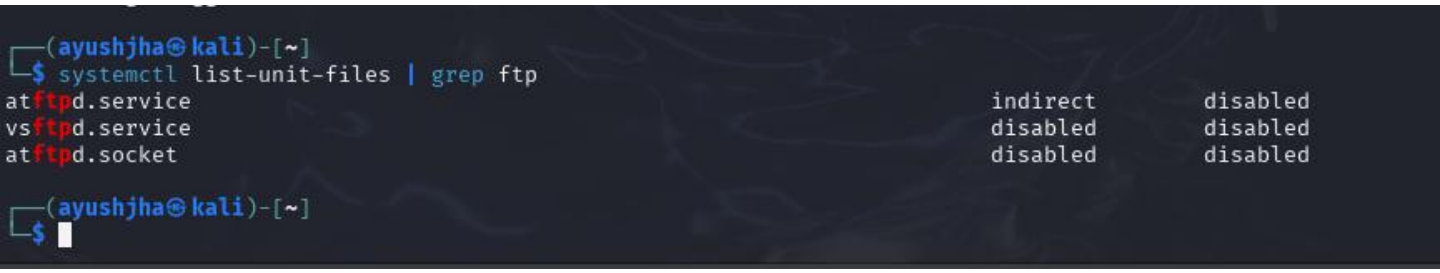


Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure echo services are not enabled	NOT MET

Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure tftp server is not enabled	MET



Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure CUPS is not enabled	MET



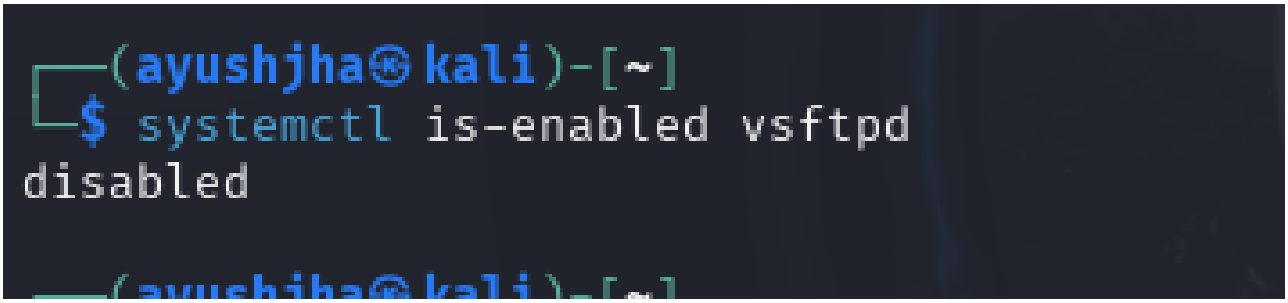
Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure DHCP Server is not enabled	MET



Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure FTP Server is not enabled	MET



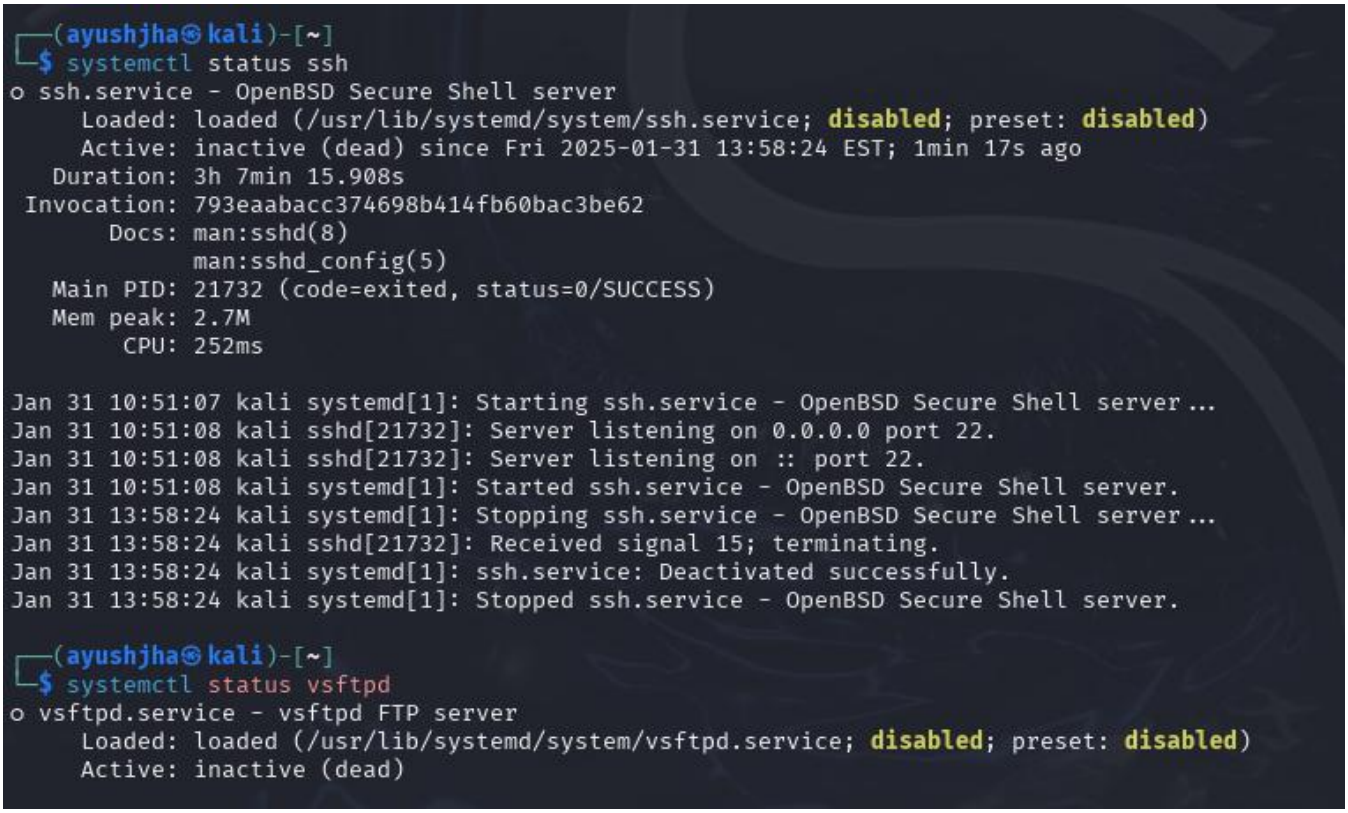
Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure Samba is not enabled	MET



Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure TCP Wrappers is installed	MET

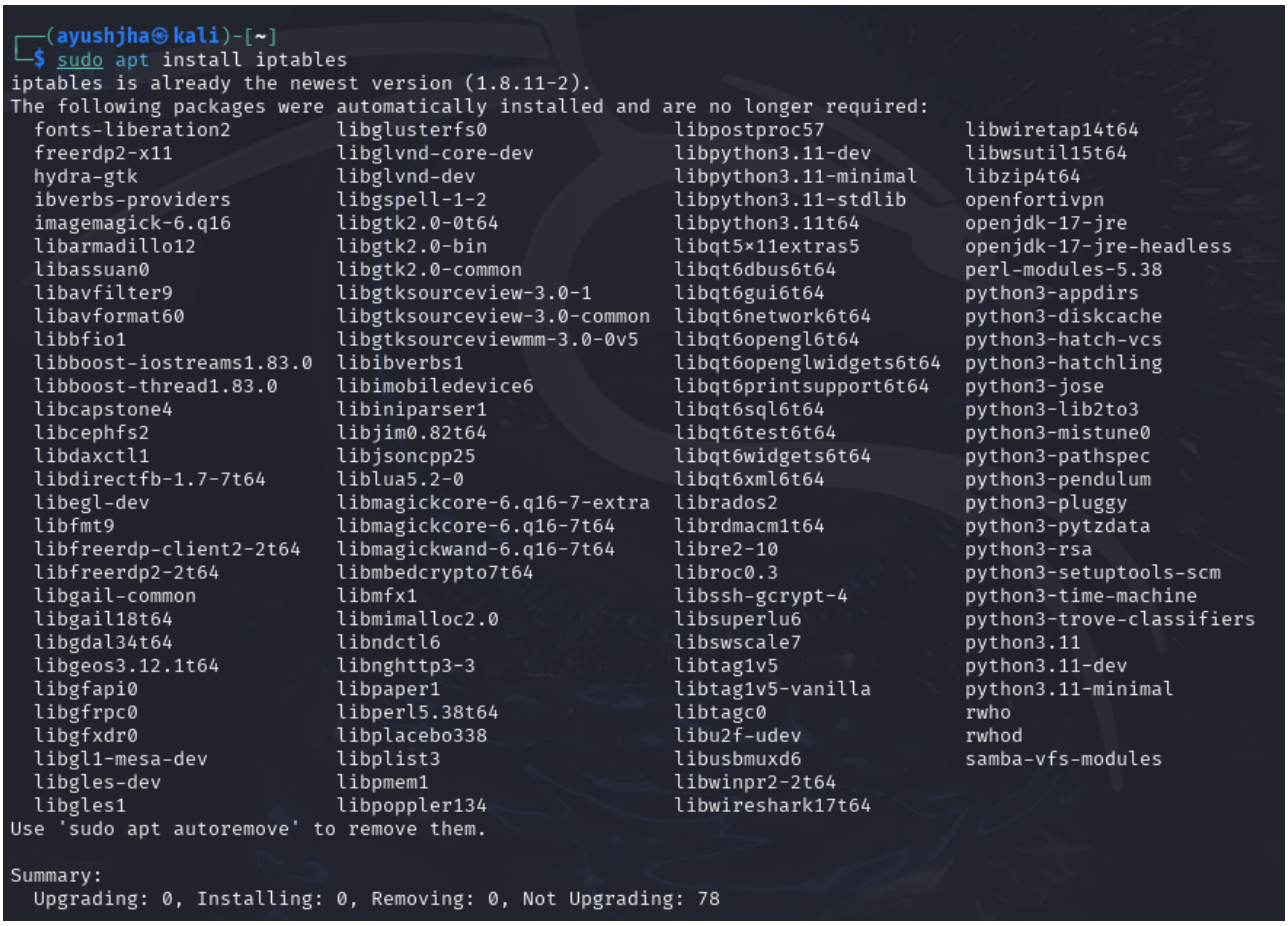


Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure DCCP is disabled	NOT MET

Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure iptables is installed	NOT MET



```
┌──(ayushjha㉿kali)-[~]
└─$ sudo apt install iptables
iptables is already the newest version (1.8.11-2).
The following packages were automatically installed and are no longer required:
  fonts-liberation2          libglusterfs0              libpostproc57              libwiretap14t64
  freerdp2-x11               libglvnd-core-dev          libpython3.11-dev          libwsutil15t64
  hydra-gtk                  libglvnd-dev               libpython3.11-minimal      libzip4t64
  ibverbs-providers          libgspell-1-2              libpython3.11-stdlib       openfortivpn
  imagemagick-6.q16          libgtk2.0-0t64             libpython3.11t64           openjdk-17-jre
  libarmadillo12             libgtk2.0-bin              libqt5×11extras5           openjdk-17-jre-headless
  libassuan0                 libgtk2.0-common           libqt6dbus6t64             perl-modules-5.38
  libavfilter9               libgtksourceview-3.0-1     libqt6gui6t64              python3-appdirs
  libavformat60              libgtksourceview-3.0-common libqt6network6t64         python3-diskcache
  libbfio1                   libgtksourceviewmm-3.0-0v5 libqt6opengl6t64           python3-hatch-vcs
  libboost-iostreams1.83.0   libibverbs1                libqt6openglwidgets6t64    python3-hatchling
  libboost-thread1.83.0      libimobiledevice6          libqt6printsupport6t64     python3-jose
  libcapstone4               libiniparser1              libqt6sql6t64              python3-lib2to3
  libcephfs2                 libjim0.82t64              libqt6test6t64             python3-mistune0
  libdaxctl1                 libjsoncpp25               libqt6widgets6t64          python3-pathspec
  libdirectfb-1.7-7t64       liblua5.2-0                libqt6xml6t64              python3-pendulum
  libegl-dev                 libmagickcore-6.q16-7-extra librados2                 python3-pluggy
  libfmt9                    libmagickcore-6.q16-7t64   librdmacm1t64              python3-pytzdata
  libfreerdp-client2-2t64    libmagickwand-6.q16-7t64   libre2-10                  python3-rsa
  libfreerdp2-2t64           libmbedcrypto7t64          libroc0.3                  python3-setuptools-scm
  libgail-common             libmfx1                    libssh-gcrypt-4            python3-time-machine
  libgail18t64               libmimalloc2.0             libsuperlu6                python3-trove-classifiers
  libgdal34t64               libndctl6                  libswscale7                python3.11
  libgeos3.12.1t64           libnghttp3-3               libtag1v5                  python3.11-dev
  libgfapi0                  libpaper1                  libtag1v5-vanilla          python3.11-minimal
  libgfrpc0                  libperl5.38t64             libtagc0                   rwho
  libgfxdr0                  libplacebo338              libu2f-udev                rwhod
  libgl1-mesa-dev            libplist3                  libusbmuxd6                samba-vfs-modules
  libgles-dev                libpmem1                   libwinpr2-2t64
  libgles1                   libpoppler134              libwireshark17t64
Use 'sudo apt autoremove' to remove them.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 78
```

Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure audit log storage size is configured	NOT MET

Linux Compliance

Linux Regulatory Requirement	Met/Not Met
Ensure audit logs are not automatically deleted	NOT MET

Section 4:
Cloud Management

Windows Server Build Sheet

1. OPERATING SYSTEM CONFIGURATION
Ensure the Windows Server OS is correctly installed, updated and configured to support web applications securely
2. SERVER HARDENING
Apply hardening guidelines from recognized security frameworks such as NIST SP 800-53 to reduce attack surfaces
3. FIREWALL AND NETWORK SECURITY
Configure firewall rules to only allow necessary inbound/outbound traffic. Eg. 1. Open only required ports. 2. Block REMOTE DESKTOP PORTS unless using VPN. 3. Enable Windows Firewall
4. SECURE REMOTE ACCESS AND AUTHENTICATION
Enforce secure authentication methods for administrative access
5. LOGGING AND MONITORING CONFIGURATION
Eg. Enable Windows Event Logs and PowerShell Loggings. Forwarding logs to SIEM solutions like Azure Sentinel Enable Sysmon for deep process tracking

Windows Server Build Sheet

6. APPLICATION AND DATABASE SECURITY

Secure web applications and databases against common threats such as SQL Injections, XSS, and unauthorized access

7. BACKUP AND DISASTER RECOVERY PLAN

Eg.

1. Enable Azure Backup, AWS Backup, or Google Cloud Backup.
2. Automate daily backups with PowerShell

8. STORAGE AND FILE SYSTEM SECURITY

Eg.

1. Use BitLocker encryption on sensitives drives.
2. Restrict IIS directories to the application user.
3. Disable anonymous access in IIS

9. PATCH MANAGEMENT AND SOFTWARE UPDATES

Ensure that the Operating System, installed applications and dependencies are regularly patched.

10. INTRUSION DETECTION AND RESPONSE PLAN

Eg.

1. Deploy Microsoft Defender ATP for endpoint protection.
2. Use OSSEC or Snort for real-time IDS alerts.
3. Automate incident response with PowerShell.

Enhancing Cloud Security with CASB

1. VISIBLITY INTO CLOUD USAGE AND SHADOW IT
CASBs provide deep visibility into cloud applications, services, and data transfers, helping security teams monitor authorized and unauthorized cloud usage.
2. DATA LOSS PREVENTION AND ENCRYPTION
CASBs enforce DLP policies to prevent unauthorized sharing or accidental exposure of sensitive data in cloud applications.
3. THREAT PROTECTION AND ANOMALY DETECTION
CASBs use AI-driven behavioral analytics to detect unusual login patterns, data exfiltration attempts, and insider threats. They also integrate with cloud-native security solutions to migrate risks.
4. COMPLIANCE ENFORCEMENT
CASBs help enforce regularly and compliance requirements by monitoring cloud environments for policy violations and ensuring alignment with Fed F1rst's security policies.
5. IDENTITY AND ACCESS MANAGEMENT INTEGRATION
CASBs integrate with IAM solutions to enforce role-based access control, least privilege principles, and single sign-on for cloud apps.